

AI-SOC-Assistant Evolution & Wins

A concise engineering brief showing how the project matured into a reproducible, explainable, and safety-conscious SOC triage pipeline with a live analyst workflow.

Capability	Professional signal
5-class family classification	Separates Normal, DoS, Probe, R2L, and U2R instead of returning only a binary anomaly flag.
Stable dual-detector triage	Combines supervised attack probability with a training-calibrated Isolation Forest risk signal.
Validated SHAP evidence	Reports real feature values and whether each contribution supports or opposes the predicted class.
Governed ticket generation	Defaults to a deterministic offline renderer and safely validates optional LLM output.
Closed analyst feedback loop	Append-only SQLite reviews promote confirmed false positives into weighted Random Forest retraining.
External generalisation evidence	A zero-tuning UNSW-NB15 transfer benchmark reports the cross-dataset gap rather than hiding it.

Engineering Evolution

1. Robust Feature Encoding and Class Balance

Categorical protocol, service, and flag fields use OneHotEncoder(handle_unknown="ignore"). Class imbalance is handled only on the training fold through deterministic duplication of exact rows, so categorical, binary, and integer telemetry is never interpolated.

Win: Novel categories no longer crash inference, and balanced training data remains valid network telemetry.

2. Stable Anomaly Calibration

Isolation Forest calibration is learned once from training-normal traffic and reused for batch and single-record scoring. The fused score uses the probability of any non-normal class rather than the classifier's maximum confidence.

Win: Alert selection and ticket generation now agree, independent of unrelated test-batch rows.

3. LangGraph Orchestration with Pinned Compatibility

The ReAct agent uses the state_modifier prompt API supported by the pinned LangGraph 0.2.53 stack, with direct provider integrations for Ollama, OpenAI, and Anthropic.

Win: Every supported provider can construct the agent graph without a version-signature failure.

4. Local-First Network Boundary

Template mode makes no network calls, and the default Compose service runs with networking disabled. Ollama keeps prompts on the configured local server; cloud providers are explicitly external. AbuseIPDB and NVD tools remain off unless SOC_ENABLE_THREAT_INTEL=true is deliberately set.

Win: Privacy claims now match the actual deployment boundary and require explicit opt-in for external lookups.

5. Live Ingestion and a Closed Feedback Loop

Delayed NSL-KDD replay and a Kafka-compatible consumer and publisher feed the same scoring runtime as the CLI. Generated alert tickets persist to SQLite, analyst reviews are append-only, and confirmed false positives re-enter training with an explicit per-row sample weight behind a versioned, atomically written artifact.

Win: The project demonstrates an operating loop rather than a batch script. Model promotion is not yet gated: retraining overwrites the single local artifact in place, and a candidate/acceptance boundary is outstanding work.

Safety, Explainability, and Evaluation

6. Threat-Intelligence Correctness and Input Safety

IP addresses and service names are validated before use. API calls have timeouts and malformed-response handling. NVD searches use a bounded 119-day publication window and sort results newest first.

Win: Unsafe inputs are rejected, and API failures cannot prevent deterministic incident-ticket generation.

7. Class-Aware SHAP Semantics

Predicted labels are mapped through the fitted model's classes_ ordering, feature schemas must match exactly, and contribution directions are described as supporting, opposing, or neutral for the predicted class.

Win: Explanations remain correct for non-contiguous labels and avoid unsupported causal attack claims.

8. Evidence-Bound GenAI Guardrails

Only allow-listed detector evidence reaches the LLM. Returned tickets must preserve validated detector semantics and evidence, use safe source-bound SPL queries, and omit raw SHAP values. Any malformed, unsafe, or provider-failed response falls back to the deterministic renderer.

Win: The optional LLM acts as a governed presentation layer rather than an authority over incident facts.

9. Protocol-Scoped, Reproducible Evaluation

Hold-out, KDDTest+ cross-distribution, and external UNSW-NB15 transfer evaluations write separate artifacts. Current results are 99.88% hold-out accuracy, 74.40% cross-distribution accuracy, and 58.89% zero-tuning transfer accuracy at 16.02% macro F1. Dataset checksums, supported Python versions, and a shared-code notebook make reruns auditable.

Win: Strong in-distribution performance is presented alongside honest rare-class, distribution-shift, and cross-dataset limits.

10. Explanation-First Analyst Interface

The Streamlit console is built on a single design-system module that defines the colour tokens, type ramp, and render helpers. SHAP drivers appear as signed contribution bars labelled as supporting or opposing the predicted class, while raw SHAP floats stay out of the ticket. Rendering helpers HTML-escape untrusted values. Model Operations now follows the refined Figma layout, with baseline protocol cards, a reviewed-cohort table, a wired feedback-weight slider, and locally served, licensed fonts.

Win: Model Operations was browser-checked at 1440, 1024, 390, and 320 px. Review queue controls and the remaining Figma states still need alignment; this is not a whole-app responsive certification.

Validation snapshot

On 9 October 2026, 155 automated tests passed locally with 73.63% coverage against a 70% CI floor; Black and flake8 passed. Local Python is 3.13.14 with pytest 8.3.4, outside the supported CI matrix. The owner confirmed passing Python 3.10-3.12 GitHub Actions jobs and the Docker build; CI also checks the image's non-root user. Container runtime testing and image scanning remain open. Dependency auditing is report-only, with remediation still outstanding. Real model-quality evaluation is not a CI gate, and retraining coverage remains 37%.

Portfolio Positioning

The repository now demonstrates not only model training, but also production-minded evidence handling, network boundaries, dependency hygiene, regression coverage, a closed analyst feedback loop, and honest evaluation across three protocols. Those qualities make the project easier to operate, review, and extend in its next implementation phase.

Updated 9 October 2026